compliance-ledger

HXC-029 — §11.4.98 Full-Automation Anti-Bluff Compliance Ledger

Field	Value
Revision	1
Created	2026-05-29
Last modified	2026-05-29
Status	active
Tracked item	HXC-029 (§11.4.98 full-automation anti-bluff forward sweep)
Pass type	**Static first-pass audit** (source reading + grep). NO tests executed. NO tests modified.

Method

§11.4.98 mandate: every live/integration/e2e/Challenge/stress/chaos test MUST be **fully self-driving end-to-end** — NO human action during execution (no "operator must type", no manual UI click, no hand-triggered webhook, no hard-coded session UUIDs colliding with the active dev session, no human-response time windows). The single permissible exception is one-time credential bootstrap performed OUTSIDE test execution.

This audit grepped the in-scope test/challenge surface for human-in-the-loop signals: `os.Stdin` reads, `fmt.Scan`, `bufio.NewReader(os.Stdin)`, `read -p` / `read -r` (stdin), prompt strings ("press enter", "type a message", "operator must", "manually", "by hand", "run manually"), `t.Skip` with manual-step reasons, human-response `time.Sleep` windows (≥30 s), hard-coded session UUIDs, interactive flags. Findings classified **COMPLIANT** / **NON-COMPLIANT** / **NEEDS-MANUAL-REVIEW**.

Scope audited (canonical tree only — `.claude/worktrees/` agent-copy duplicates were EXCLUDED as non-canonical): - `helix_code/tests/{integration,e2e,security,performance}/**` - `helix_qa/**` (banks, challenge scripts, executor `pkg/`, runner `cmd/`) - `challenges/**` challenge scripts (`challenges/challenges/scripts/`, `challenges/p1-*`, `challenges/p2-*`, `challenges/lib`) - `*.sh` challenge / live-test scripts under the repo

Greps run (representative, all from repo root):

```
grep -rn "os.Stdin|bufio.NewReader(os.Stdin)|fmt.Scan|ReadString('\n')|Std
grep -rni "press enter|type a message|operator must|manually|by hand|run m
grep -rn "t.Skip" helix_code/tests/ | grep -iv testing.Short
grep -rni "press enter|read -p|read -r |type a message|operator must|manua
grep -rniE "[0-9a-f]{8}-...-...-...-[0-9a-f]{12}|claude --resume|--session
grep -rniE "manual|operator must|press enter|interactive: *true" helix_qa/
grep -rnE "time.Sleep\((30|[4-9][0-9]|[0-9]{3,})\s*\*\s*time.Second|...tim
```

Classification table

Test/Suite (path)
`helix_code/tests/integration/askuser_test.go`
`helix_code/tests/regression/server_timeout_test.go`
`helix_code/tests/e2e/scripts/clean.sh`
`helix_qa/banks/full-qa-web.json` (572 entries)
`helix_qa/banks/atmosphere.json` (423 entries)
`helix_qa/banks/full-qa-android.json` (318 entries)
`helix_qa/banks/performance-validation.json` (116)
`helix_qa/banks/storage-configuration.json` (88)

Test/Suite (path)
helix_qa/banks/cli-agents-comprehensive.json (79)
helix_qa/banks/edge-cases-stress.json (78)
helix_qa/banks/aichat-bash-tools-comprehensive.json (72)
helix_qa/banks/cli-agents-test-helixagent.json (71)
helix_qa/banks/editor-operations.json (63)
helix_qa/banks/cloud-storage-operations.json (63)
helix_qa/banks/file-browser.json (61)
helix_qa/banks/app-navigation.json (54)
helix_qa/banks/security-validation.json (41)
helix_qa/banks/all-formats.json (40)
helix_qa/banks/entity-management.json (38)
helix_qa/banks/full-qa-cross-platform.json (37)
helix_qa/banks/admin-operations.json (29)
helix_qa/banks/full-qa-api.json (27)

Test/Suite (path)
`helix_qa/challenges/scripts/ui_terminal_interaction_challenge.sh`
`helix_qa/challenges/scripts/ux_end_to_end_flow_challenge.sh`
`helix_qa/challenges/scripts/{chaos_failure_injection,ddos_health_flood,scaling_horizontal,stress_sust` `_challenge.sh`
`challenges/p1-f06..p2-f24/run.sh` (20 scripts)
`helix_code/tests/integration/*.go` (most: simple, workflow_tools, integration, cognee, api, mu memory, mcp_stdio, background_shell, planmode_gating, markdown_commands, skills, sessions_resume, lsp telemetry, smartedit, approval, autocommit, browser, theme, auto_compaction)
`helix_code/tests/e2e/**` (complete_workflow_test, e2e_test_framework, challenges/, *core/*, phase2/ orchestrator/*)
`helix_code/tests/security/*.go` (authentication, authorization, tools_security, owasp, simple)
`helix_code/tests/performance/*.go` (benchmark, competitor_baseline, pprof_harness, pgo, scen

Counts by classification

Classification	Count	Notes
COMPLIANT	4	askuser_test.go; ui_terminal_interaction_challenge.sh; ux_end_to_end_flow_challenge.sh; (askuser explicitly anti-bluff via bytes.Buffer)
NON-COMPLIANT	2	server_timeout_test.go (manual-only `TestServerStability`); clean.sh (interactive `read -p` — helper, lower severity)

Classification	Count	Notes
NEEDS-MANUAL-REVIEW	19 banks + ~24 Go integration files + ~all e2e/security/performance suites + chaos/scaling/ feature challenge scripts	Predominantly: (a) HelixQA banks with `manual-review-required` converted-prose steps that the executor SKIPs (not human-driven, but origin needs review); (b) integration/e2e suites where grep finds no manual signal but true unattended self-driving is not statically provable.

Honest summary: Only **2 genuinely NON-COMPLIANT** §11.4.98 findings were located by static analysis with cited file:line. The 19 HelixQA banks carrying `manual-review-required` are NOT confirmed live manual-intervention violations — the executor SKIPs unrecognised prose steps (`schema.go:101-102`, `structured_executor.go:241-247`) and SKIPs `ActionTypePlaywright` steps with `PLAYWRIGHT-RUNTIME-PENDING` (`schema.go:189-191`) — but their converted-from-manual origin and un-executed state warrant human review per §11.4.98's obsolescence-audit clause (manual-dependency tests not rewritten within 30 days → §11.4.90 Obsolete).

Top NON-COMPLIANT to rewrite first (prioritized)

1. `helix_code/tests/regression/server_timeout_test.go:121` — `TestServerStability`**.** The ONLY confirmed code-level §11.4.98 violation: a test gated entirely on manual human invocation (`t.Skip("…run manually for verification")`) whose body never actually starts the server (stub comment "In a real test, we would start the server"). Rewrite to programmatically boot the server, run for `2× IdleTimeout`, assert no premature shutdown — fully unattended. (Also a §11.4 PASS-bluff: skipped + non-functional.)

2. **HelixQA** `full-qa-web.json` **(572** `manual-review-required`**,** `ActionTypePlaywright` **PLAYWRIGHT-RUNTIME-PENDING).** Largest converted-from-manual bank. Wire the Playwright runtime (`PlaywrightCLIAdapter` per `schema.go:186`) so the 572 web steps actually execute unattended instead of SKIPping — currently the largest block of "looks covered but does not run" surface.

3. **HelixQA** `atmosphere.json` **(423)** + `full-qa-android.json` **(318).** Next-largest converted-prose banks; confirm every `manual-review-required` step maps to an executable `adb_shell/tap/http/assert` action with NO residual human step, or mark Obsolete per §11.4.98(F)/§11.4.90.

4. `helix_code/tests/e2e/scripts/clean.sh:59` — **interactive** `read -p`**.** Replace the `y/N` prompt with a `--force` / `CLEAN_TEST_RESULTS=1` env-driven non-interactive path so any pipeline invoking it never blocks on stdin. (Helper, not a governed test, but blocks automation.)

5. **Remaining** `*-validation/*-operations/*-comprehensive` **HelixQA banks (performance-validation 116, storage-configuration 88, cli-agents-comprehensive 79, edge-cases-stress 78, …).** Batch-audit the `manual-review-required` entries for any genuine human dependency, then either make executable or Obsolete.

Limitations of this static pass

A static grep + source read CANNOT determine the following — these require runtime execution (out of scope for this pass) or human review:

1. **Runtime human dependence not visible in source.** A test with no prompt string may still block on an external system that only a human can advance (e.g. an OAuth consent screen, a device-pairing tap) without any literal "press enter" in the code.
2. **Whether SKIPPED prose/Playwright steps would demand human action IF wired.** The executor currently SKIPs them; the original manual intent (`_original_action`) is prose like "Open … in the browser" — only review of the converted action confirms no human is expected once the runtime lands.
3. **Re-runnability (`-count=3` consecutive PASS with self-cleaning state)** per §11.4.98(C) — provable only by running the tests, which this pass did not do.
4. **Hidden human-response time windows** implemented via channels, context deadlines, or polling loops that wait on externally-injected human input without an obvious `time.Sleep` literal.
5. **Hard-coded session-UUID collisions** with a live dev session — the UUIDs found (`00000000-…-0001`, slack mock `550e8400-…`) are fixed test fixtures, but a collision hazard depends on the runtime session ID, unknowable statically.
6. **Banks not loaded by any active runner.** Whether a given bank is actually executed in a QA session (vs orphaned) was not traced end-to-end; an unexecuted bank cannot violate §11.4.98 at runtime regardless of its contents.
7. `.claude/worktrees/` **duplicates were excluded** as non-canonical agent copies; if any are independently executed, they were not audited here.

Sources verified

Internal source-of-truth files read during this audit (no external web sources — this is a static code audit, not a documentation-authoring task under §11.4.99): - `helix_qa/pkg/testbank/schema.go` (ActionType taxonomy, ParseAction, SKIP semantics) - `helix_qa/pkg/autonomous/structured_executor.go` (step dispatch + placeholder skip) - `helix_code/tests/integration/askuser_test.go` - `helix_code/tests/regression/server_timeout_test.go` - `helix_code/tests/e2e/scripts/clean.sh` - `helix_qa/challenges/scripts/{ui_terminal_interaction,ux_end_to_end_flow}_challenge.sh`